ACC-10 · Guest & Sponsored External Account Standard

Which kind of identity an outsider should have, who sponsors it, and how it ends. The account side of external collaboration.

Field	Value
Document ID	ACC-10
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 2 — Advanced Technical Services creates and manages; Tier 3 owns the tenant identity configuration.
Review cycle	Annually.
Relationship to M365-14	This document governs the identity — which kind, who sponsors it, how it ends. M365-14 governs what it can reach. Read together; neither repeats the other.

1. Purpose

This document answers a question that arrives regularly and is usually answered by whoever is asked: somebody outside the organization needs to work with us — what kind of account should they have?

Getting it wrong in one direction creates a guest for a person who is effectively staff and needs a real account. Getting it wrong in the other creates a full organization identity for a consultant who needed read access to one site for six weeks. Both happen, and both are avoidable with a short decision table.

2. Choosing the right kind of identity

Kind	Use when	What they get	Governed by
Guest (B2B)	Someone at another organisation collaborating on specific work. The default and the great majority of cases.	They sign in with their own organisation's credentials. No mailbox of ours, no licence, no presence in the address book beyond what is needed.	This document + M365-14
Vendor or contractor account	A supplier with standing operational access — an implementation partner on the HR system, a managed security provider in the security tooling.	A named identity of ours, because they need to act inside our systems rather than collaborate on documents.	ACC-11, plus ACC-07 where the access is privileged

Kind	Use when	What they get	Governed by
Full staff account	A person doing the work of an organization employee, whatever their contractual status — long-term consultants, seconded staff, interim appointments.	A normal identity with an HR record behind it.	ACC-01. Requires HR to create the record first.
Nothing	They need a document, not access.	Send them the document, or a link with an expiry.	M365-14 §6

The case worth watching for

A consultant who becomes, in practice, a member of staff — attending meetings, holding institutional records, doing the work of a role — while still holding an external or personal identity.

A familiar version: a departing senior figure explains that their organization files are in a personal OneDrive because they originally joined as a consultant. The identity arrangement made at the start was never revisited when the relationship changed, and the cost lands years later during a transition.

So: when an external relationship becomes ongoing and substantive, that is a trigger to revisit the identity, not a detail to leave alone because it works.

Check your tenant first

Look at the allowInvitesFrom setting. If it is adminsGuestInvitersAndAllMembers (a common default), every member of the organization can invite a guest, with no sponsor recorded, no purpose captured and no expiry applied.

Count the guests in the tenant, and check whether any of them has a sponsor or an expiry recorded anywhere. Usually none do, because there has been nowhere to record one.

While you are there, check whether users can register applications or create security groups; both matter for M365-07 and M365-14.

Changing allowInvitesFrom is a one-setting change under M365-21 and GOV-04. It should not be made before §3 and §4 of this document are agreed, or the organization simply replaces an ungoverned invitation path with a queue nobody can staff.

3. The sponsor

Every external identity has one named staff member accountable for it. Not a department — a person.

The sponsor	
Asks for it	Raises the request, states the purpose in one sentence, and names the end date.
Vouches for it	Is saying, on the record, that this person should have access to organization systems. That is a real statement and it should feel like one.
Confirms it at review	Answers one question before expiry: does the purpose still hold?

The sponsor	
Ends it	Tells the service desk when the work is finished, without waiting for expiry. Sponsors should be thanked for this rather than made to feel they are creating work.
Is replaced when they leave	A guest whose sponsor has left is reassigned or expired as part of the leaver procedure (ACC-01 §7.2 step 9).

4. Creating a guest

> **Only IT Account Services creates external identities. End-user invitation is disabled.**
> This is the control whose absence causes the problem. When any staff member can invite an external identity, nobody can answer how many exist, who vouched for them, or what they can reach.
> The cost is a request. The mitigation is that the request is a same-day action (§8) — if it is not, people will find another way and the control will erode.

1. The sponsor raises a ticket with the person's name, organisation, email address, purpose, what they need to reach, and the end date.
2. Tier 2 confirms a guest is the right kind of identity (§2). Where it is not, redirect rather than create the wrong thing quickly.
3. Create the guest. Set the display name to include the organisation — "Alex Morgan (Contoso)" — so that any member of staff can see at a glance that they are external.
4. Record the sponsor, purpose, scope and expiry in the guest register at the moment of creation. A register updated later is a register with gaps.
5. The guest registers MFA before reaching anything. External identities meet the same authentication requirement as organization accounts (ACC-03 §5.1).
6. Grant access per M365-14 — to a group, scoped to the purpose, never broader "in case".
7. Tell the sponsor the expiry date at creation.

5. What a guest is not

- Not a mailbox holder. Guests do not receive an address at your domain and do not send as the organization.
- Not a licence holder, unless a specific licensing need is identified and approved (M365-20).
- Not an owner. A guest never owns a site, mailbox, Team or group — ownership is a staff responsibility (M365-10, M365-03).
- Not a holder of any administrative role (ACC-07). Where a vendor genuinely needs administrative access, that is ACC-11 and a different kind of account.
- Not permanent. A relationship that needs to be permanent is not a guest relationship (§2).
- Not in the address book by default, so that internal mail does not autocomplete to an external party — a small setting that prevents a specific and embarrassing class of mistake.

6. Expiry, renewal and removal

- Default expiry 90 days, set at creation, renewable.
- Fourteen days before expiry, the sponsor is asked one question: does the purpose still hold?
- No response means expiry. Renewal is the action; expiry is the default. This single rule is what prevents guest accumulation.
- Renewal extends 90 days and records the confirmation.
- Quarterly, the full guest register goes to Tier 4: person, organisation, sponsor, purpose, scope, expiry, last sign-in. A guest with no identifiable sponsor is removed rather than researched.
- Removal takes away access; anything the guest contributed stays with the organization. Worth telling sponsors who hesitate.
- On a security concern, removal is immediate on Tier 4 instruction (GOV-03).

7. Identity configuration

Tier 3 owns these; changes go through M365-21. Recorded here so the intent sits with the standard.

Setting	Intent
Who can invite guests	IT Account Services only.
Guest MFA	Required, like every other identity.
Guest access to the directory	Restricted — guests should not be able to enumerate the organization’s people.
Guest visibility in the address book	Hidden by default (§5).
Guest inactivity reporting	Quarterly, feeding §6.
Allowed and blocked domains	Reviewed annually. Maintain a blocked list only where there is a specific reason to.
Automatic expiry enforcement	Enabled where the platform supports it, so §6 is a configuration rather than a habit.

8. Service levels

Activity	Commitment (per GOV-06)
Guest creation, complete request	P3 — same coverage day where possible.
Wrong kind of identity requested	Redirected same day with an explanation, not held silently.
Renewal on sponsor confirmation	Same day.
Removal on sponsor request	Same day.
Urgent removal on security grounds	P1 — 30 minutes.
Quarterly register to Tier 4	On schedule.

9. Records

Record	Held in	Retention
Guest register, complete at creation	IT register	Live, plus 3 years after removal
Sponsor’s request and vouching	Ticket	3 years
Renewals and confirmations	Ticket	3 years
Quarterly review outcomes	Tier 4 record	3 years
Identity-kind decisions where a guest was not the answer	Ticket	3 years

10. Related documents

ID	Title	Relationship
M365-14	External Sharing & Guest Access Governance	What a guest can reach. The companion to this document.
ACC-11	Vendor, Contractor & Consultant Account Standard	The next kind of identity up (§2).
ACC-01	Account Lifecycle	Full accounts, and §7.2 step 9 sponsor departure.
ACC-03	MFA Enrollment	Guests register like everybody else.
ACC-02	Account Naming Standard	§3 guest display-name rule.
ACC-07	Privileged & Administrative Account Standard	Guests hold no administrative role.
M365-20	License Assignment & Reclamation	Guest licensing exceptions.
M365-21	Tenant Configuration Change Control	Changes to §7.
GOV-03	Security Incident Response	Urgent removal.

Appendix A — Which identity does this person need?

	Are they...	Then
1	Doing the work of an organization employee, ongoing?	A full staff account. HR creates the record first (ACC-01).
2	A supplier needing standing operational access to our systems?	A vendor account (ACC-11), plus ACC-07 if it is privileged.
3	Collaborating on specific work for a bounded period?	A guest. This document.
4	Just needing to receive a document?	Send it, or a link with an expiry. No account at all.
5	A consultant whose engagement has quietly become ongoing?	Revisit it. This is the case that costs the most later.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.